

MCP Threat Model

Owner: William
Reviewer: Charoes
Contributors:
Date Generated: Fri Oct 10 2025

Executive Summary

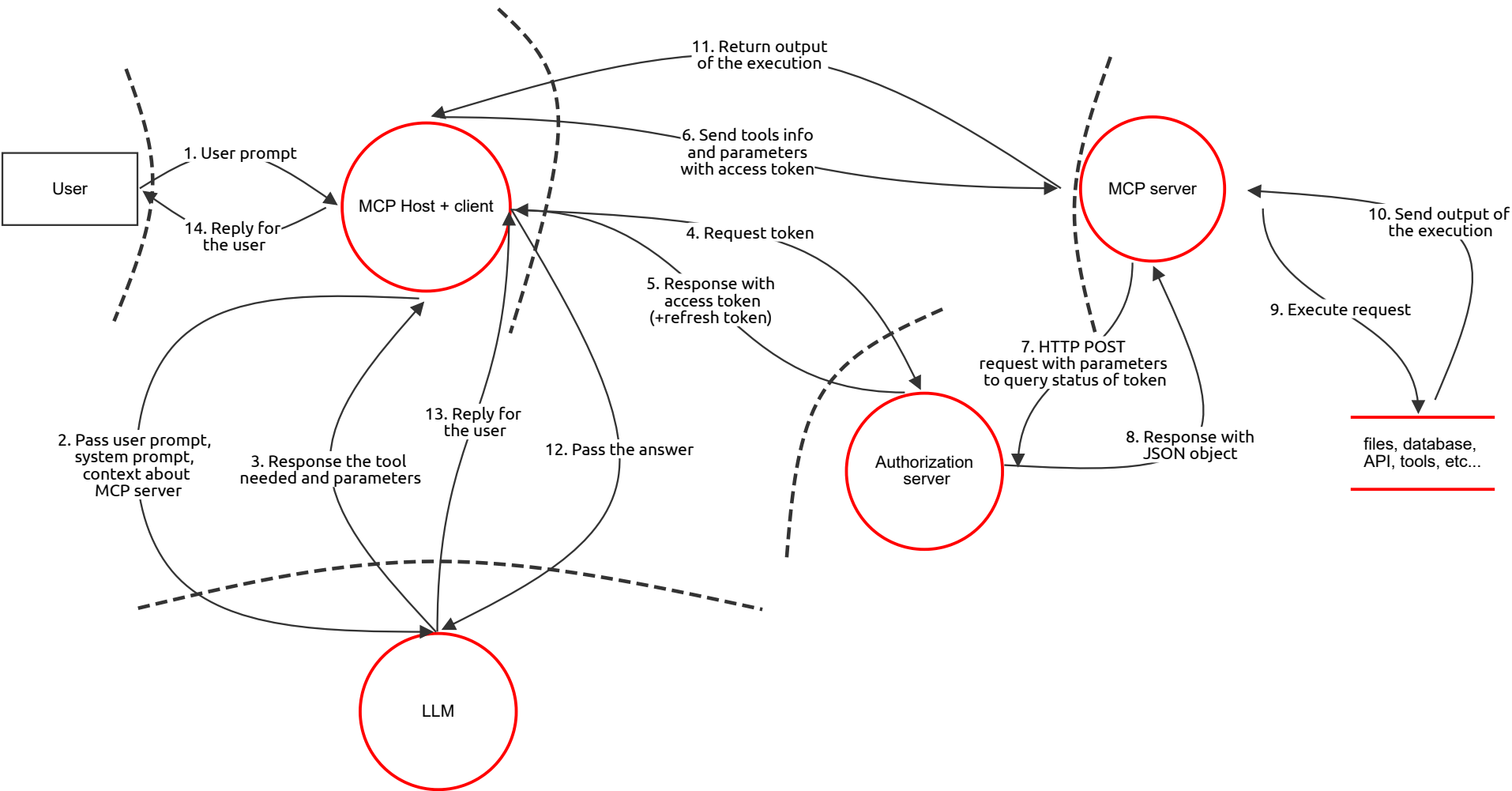
High level system description

MCP (Model Context Protocol) is an open-source standard for connecting AI applications to external systems.

Summary

Total Threats	35
Total Mitigated	0
Total Open	35
Open / Critical Severity	1
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0
Open / TBD Severity	34

MCP Threat Model



MCP Threat Model

MCP Host + client (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Client side - Impersonation	Spoofing	TBD	Open		Attackers posing as legitimate clients to gain unauthorized access	Defences include providing enforcement of behavioral workflow and anti-automation
2	Client side - Insecure Communication	Tampering	TBD	Open		Vulnerabilities leading to interception or data alteration during transmission	Defence includes providing anti-automation
3	Client side - Operational Errors	Denial of service	TBD	Open		Schema inconsistencies between client and server causing functional errors	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
4	Client side - Unpredictable Behavior	Denial of service	TBD	Open		Model instability prompting disruptive or unexpected requests	Provide remediation for this threat or a reason if status is N/A
5	Host side - AI Model Vulnerabilities	Denial of service	TBD	Open		Hallucinations, instability, or specific exploits resulting in erroneous MCP utilization	Provide remediation for this threat or a reason if status is N/A
6	Host side - Host System Compromise	Elevation of privilege	Critical	Open		General compromise of the host system affecting MCP client security	Provide remediation for this threat or a reason if status is N/A

LLM (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
21	LLM01: Prompt Injection	Tampering	TBD	Open		Manipulating LLMs via crafted inputs can lead to unauthorized access, data breaches, and compromised decision-making	Provide remediation for this threat or a reason if status is N/A
75	LLM02: Insecure Output Handling	Information disclosure	TBD	Open		Neglecting to validate LLM outputs may lead to downstream security exploits, including code execution that compromises systems and exposes data.	Provide remediation for this threat or a reason if status is N/A
76	LLM03: Training Data Poisoning	Tampering	TBD	Open		Tampered training data can impair LLM models leading to responses that may compromise security, accuracy, or ethical behavior	Provide remediation for this threat or a reason if status is N/A
77	LLM04: Model Denial of Service	Denial of service	TBD	Open		Overloading LLMs with resource-heavy operations can cause service disruptions and increased costs.	Provide remediation for this threat or a reason if status is N/A
78	LLM05: Supply Chain Vulnerabilities	Tampering	TBD	Open		Depending upon compromised components, services or datasets undermine system integrity, causing data breaches and system failures.	Provide remediation for this threat or a reason if status is N/A
79	LLM06: Sensitive Information Disclosure	Information disclosure	TBD	Open		Failure to protect against disclosure of sensitive information in LLM outputs can result in legal consequences or a loss of competitive advantage.	Provide remediation for this threat or a reason if status is N/A
80	LLM07: Insecure Plugin Design	Elevation of privilege	TBD	Open		LLM plugins processing untrusted inputs and having insufficient access control risk severe exploits like remote code execution.	Provide remediation for this threat or a reason if status is N/A
81	LLM08: Excessive Agency	Information disclosure	TBD	Open		Granting LLMs unchecked autonomy to take action can lead to unintended consequences, jeopardizing reliability, privacy, and trust.	Provide remediation for this threat or a reason if status is N/A
82	LLM09: Overreliance	Information disclosure	TBD	Open		Failing to critically assess LLM outputs can lead to compromised decision making, security vulnerabilities, and legal liabilities.	Provide remediation for this threat or a reason if status is N/A
83	LLM10: Model Theft	Information disclosure	TBD	Open		Unauthorized access to proprietary large language models risks theft, competitive advantage, and dissemination of sensitive information.	Provide remediation for this threat or a reason if status is N/A

1. User prompt (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2. Pass user prompt, system prompt, context about MCP server (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

3. Response the tool needed and parameters (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

6. Send tools info and parameters with access token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

4. Request token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

5. Response with access token (+refresh token) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

9. Execute request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

10. Send output of the execution (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

11. Return output of the execution (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

12. Pass the answer (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

13. Reply for the user (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

14. Reply for the user (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

8. Response with JSON object (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

7. HTTP POST request with parameters to query status of token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

MCP server (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Compromise and Unauthorized Access	Spoofing	TBD	Open		Vulnerabilities in deployment or security configurations that permit attacker access	Defences include providing enforcement of behavioral workflow and anti-automation
8	Exploitation of Functions	Tampering	TBD	Open		Vulnerable tools potentially utilized to execute harmful operations	Defence includes providing anti-automation
9	Denial of Service	Denial of service	TBD	Open		Server flooding through excessive requests or autonomous agent loops	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock loops
10	Vulnerable Communication	Tampering	TBD	Open		Interception or modification of data between client and server	Provide remediation for this threat or a reason if status is N/A
11	Client Interference	Denial of service	TBD	Open		Insufficient isolation allowing one client’s behavior to affect others	Provide remediation for this threat or a reason if status is N/A
12	Data Leakage and Compliance Violations	Information disclosure	TBD	Open		Unauthorized data exfiltration or regulatory violations	Provide remediation for this threat or a reason if status is N/A
13	Insufficient Auditability	Repudiation	TBD	Open		Inadequate logging restricting detection and investigation of security events	Provide remediation for this threat or a reason if status is N/A
14	Server Spoofing	Spoofing	TBD	Open		Malicious servers posing as legitimate ones within the ecosystem	Provide remediation for this threat or a reason if status is N/A

User (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

files, database, API, tools, etc... (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	Data - Insufficient Access Control	Information disclosure	TBD	Open		Inadequate security measures on underlying data sources enabling unauthorized access	Defences include providing enforcement of behavioral workflow and anti-automation
16	Data Integrity Issues	Tampering	TBD	Open		Data drift or intentional tampering leading to misleading results	Defence includes providing anti-automation
17	Data Exfiltration	Information disclosure	TBD	Open		Unauthorized extraction of confidential information through compromised connections	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
18	Tool - Functional Misuse	Tampering	TBD	Open		Tools utilized for improper or harmful purposes beyond intended functionality	Provide remediation for this threat or a reason if status is N/A
19	Tool - Resource Exhaustion	Denial of service	TBD	Open		Excessive tool usage overwhelming system resources	Provide remediation for this threat or a reason if status is N/A
20	Tool - Tool Poisoning	Tampering	TBD	Open		Malicious manipulation of tool descriptions or parameters to induce unintended model behavior	Provide remediation for this threat or a reason if status is N/A

Authorization server (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
70	Eavesdropping Access Tokens	Information disclosure	TBD	Open		Attackers may attempt to eavesdrop access tokens in transit from the authorization server to the client.	Provide remediation for this threat or a reason if status is N/A
71	Obtaining Access Tokens from Authorization Server Database	Information disclosure	TBD	Open		This threat is applicable if the authorization server stores access tokens as handles in a database. An attacker may obtain access tokens from the authorization server's database by gaining access to the database or launching a SQL injection attack.	Provide remediation for this threat or a reason if status is N/A
72	Disclosure of Client Credentials during Transmission	Information disclosure	TBD	Open		An attacker could attempt to eavesdrop the transmission of client credentials between the client and server during the client authentication process or during OAuth token requests.	Provide remediation for this threat or a reason if status is N/A
73	Obtaining Client Secret from Authorization Server Database	Information disclosure	TBD	Open		An attacker may obtain valid "client_id"/secret combinations from the authorization server's database by gaining access to the database or launching a SQL injection attack.	Provide remediation for this threat or a reason if status is N/A
74	Obtaining Client Secret by Online Guessing	Information disclosure	TBD	Open		An attacker may try to guess valid "client_id"/secret pairs.	Provide remediation for this threat or a reason if status is N/A